

Halden Distribution Ltd. — Endpoint security standard

Document ID: STD-ENDPOINT-001 · **Version:** 1.0 (draft for approval) · **Owner:** IT (M. I. Akmal) **Applies to:** every Windows PC, laptop and shared terminal issued by Halden, including devices used for remote work · **Effective from:** on approval · **Review:** annually, or after any baseline change

Written to be read and approved by a manager, not only by a technician. Each requirement states **what is enforced, why it exists** and **what a user will actually notice**. The technical settings behind each one are in `configs/baseline-policy.yaml`, `configs/asr-rules.yaml` and `configs/compliance-controls.yaml`.

1. Purpose

Halden has grown without a written standard for its own computers. This document sets one. It exists so that:

- a stolen or lost device does not become a data breach;
- one compromised PC does not become a company-wide incident;
- IT support is predictable, because every machine is built to the same rules;
- the business can say, with evidence, what state its devices are in.

2. Scope and responsibilities

Item	In scope	Out of scope
Devices	Windows workstations, laptops, shared terminals, remotely used devices	Servers (covered by the infrastructure standard), network devices, printers
Responsibility	IT implements and evidences; department heads approve exceptions; users follow the rules below	—

Approval: this standard is approved by the Managing Director, and changes to it follow the same change process as any other IT change (see `p04-change-record.md`).

3. The requirements

3.1 Encryption — every device, no exceptions

What	Why	What the user notices
Full-disk encryption (BitLocker, XTS-AES 256) on the operating system drive, enabled with the device's TPM	A laptop that leaves the building is the most likely way Halden's data leaves with it. Encryption makes a stolen device worthless to a thief.	Slower first setup only. Otherwise nothing.
The recovery key is stored in Active Directory, accessible only	Encryption without a recoverable key turns a hardware fault into permanent	If the user ever sees a recovery screen, the Service Desk will ask

What	Why	What the user notices
to IT, and released only after the caller's identity is verified	data loss. An unescrowed key is worse than no encryption, because it feels safe.	for identity details before helping. That is deliberate.
Fixed data drives are encrypted on the same basis	A removed disk bypasses an unencrypted volume entirely.	Nothing.

3.2 Least privilege — no standing local administrator rights

What	Why	What the user notices
Standard staff accounts are not members of the local Administrators group. The only members are the LAPS-managed local administrator account and the IT administration group	A local administrator can switch off every other control in this document. Removing the rights is what makes the rest of the standard hold.	Installing software is a request to IT rather than something done personally. See §4.
The local administrator password is unique per device and rotated	One shared password means one leak opens every machine in the company.	None.
IT administration accounts are separate from everyday accounts and are used only for administration	An administrator who reads email in an admin session is one click away from a domain-wide compromise.	IT staff sign in twice.

3.3 Protection against malicious behaviour

What	Why	What the user notices
Defender Antivirus with cloud protection, and Attack Surface Reduction rules blocking the behaviours attackers rely on (macros spawning programs, script abuse, credential theft, ransomware patterns)	Ransomware and phishing payloads run on endpoints and use these behaviours. Blocking the behaviour works even before a signature exists.	Occasionally a file or macro is blocked. This is the control working; see the "my device is blocked" runbook.
Every rule is proved with a logging period before it is enforced , and any exclusion is approved, recorded and given an expiry date	Hardening that breaks the month-end close gets switched off by the business within a week, and then nothing is protected.	A short trial period before anything changes for users.
Firewall enabled on all profiles, with inbound connections denied by default and remote management allowed only from IT's own network range	A device with the firewall off is a machine listening to anyone on the same network.	Nothing, in normal use.

3.4 Credential and audit protections

What	Why	What the user notices
Credential Guard where the hardware supports it, and LSA protection	Stolen credentials are the most common way an attacker turns one compromised PC into a domain compromise.	Nothing, apart from a restart during setup.
PowerShell script logging and module logging on production	When something does go wrong, the record has to exist already. Logging is how an incident becomes	Nothing.

What	Why	What the user notices
devices	answerable.	

3.5 Service and patch level

What	Why	What the user notices
Every device runs a supported Windows version and is patched on the ring schedule owned by the patch programme (P5)	An unsupported device receives no security fixes, whichever other settings are applied to it.	Restarts at agreed times.
Devices are re-checked automatically every day against the standard, and non-compliance is reported to management	A standard nobody measures is a wish. The result is one percentage, not an opinion.	Occasionally IT will fix something on the device.

4. How a user requests software (the practical half of least privilege)

The rule is simple: **users do not install software; they request it.** The process exists to make that faster than doing it yourself.

1. User raises a ticket with the software name, the business reason and any deadline.
2. The line manager approves it as a business need.
3. IT chooses the safest route:
 - **Package and deploy** — IT installs it with the required rights; the user needs none. This is the

normal outcome.

- **Time-limited elevation** — for a genuine one-off, IT grants a named elevation that expires automatically and is logged.
- **Exception** — only if the first two are impossible; recorded with a risk, an owner and an expiry.
- The user is told the outcome, and the reason if the answer is no.

Emergency: if a business-critical task is blocked, the Service Desk can act immediately and complete the paperwork afterwards.

5. Exceptions

- Any deviation from this standard needs a signed exception with a **business reason**, a ****risk statement**, a **named owner** and an **expiry date****.
- Exceptions live in `p04-asr-exceptions.md` (and `configs/baseline-exceptions.csv` for machine-readable

rows) and are reviewed at each monthly IT review.

- An expired exception is removed automatically; renewing it requires a new approval.
- "It has always been like that" is not a reason; it is a finding waiting to be written.

6. Compliance and evidence

Activity	Frequency	Evidence
Automated endpoint compliance check (nine controls)	Daily	reports/endpoint-compliance-<date>.html + .csv ; overall percentage trended
Exception register review	Monthly	Updated register with expired rows removed
Recovery procedure tested	At least every six months	Recorded recovery test with the time taken
Standard review	Annually	Updated version of this document with the approval date
Backup of the device to the file server / backup service	As per the backup standard (P8)	Backup reports; note that backup does not replace encryption

7. What is deliberately *not* required (and why)

Being explicit about what the standard does not demand is as important as the requirements:

- **Removable storage is not blocked.** Warehouse scanners and stock guns are in daily use; blocking USB wholesale would stop work. Only unsigned or untrusted programs running from removable media are blocked.
- **BitLocker does not require a PIN by default.** TPM-only is the standard for general devices; a PIN would add a support call per forgotten PIN. It remains an option for devices carrying Finance or HR data, decided case by case.
- **Application allow-listing (AppLocker) is not enforced.** There is no signed line-of-business package yet, so an enforced allow-list would block work. It runs in audit mode as a stepping stone.
- **Aggressive credential-caching limits are not applied.** Remote sales staff must be able to sign in offline.

8. Approval

This standard takes effect when approved. Until then it is a draft and nothing may claim compliance with it.

Approved by (Managing Director):

Date:

Owner (IT): Muhammad Ibrahim Akmal · Review date: 12 months from approval.

Lab note: Halden Distribution Ltd. is fictional; this is a home-lab portfolio artefact. The technical content reflects real, executable configuration, and the approval line is deliberately unsigned.

